

Clase 208 — Forense de red

Parte: **9 — Forense digital y respuesta a incidentes** · Fuente: *NIST SP 800-86* y documentación de Wireshark/Zeek 🕒 Duración estimada: **130 min** · Nivel: **Avanzado**

Objetivo

Aprender a reconstruir lo que pasó en la red durante un incidente a partir de capturas de paquetes (PCAP) y registros de flujo. Al terminar podrás identificar exfiltración, canales de mando y control (C2), tunneling y movimiento lateral usando Wireshark, tshark, Zeek y NetworkMiner.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Capturar y filtrar** tráfico con tcpdump, Wireshark y tshark.
- 2. **Reconstruir** sesiones y extraer archivos transferidos de un PCAP.
- 3. **Detectar** C2, beaconing y exfiltración por DNS/HTTP.
- 4. **Analizar** logs de Zeek para hallar anomalías a escala.
- 5. **Distinguir** tráfico legítimo de indicadores de compromiso.

Temas

#	Tema	Por qué importa
1	Fuentes: PCAP vs. flujo (NetFlow)	Detalle vs. escala
2	Filtros de captura y display	Encontrar la aguja
3	Reensamblado de sesiones TCP	Ver la conversación completa
4	Extracción de archivos	Recuperar lo transferido
5	Detección de C2 y beaconing	Patrón periódico revelador
6	Exfiltración por DNS/HTTP	Canales encubiertos
7	Zeek (logs de red)	Análisis a gran escala
8	TLS y tráfico cifrado	Metadatos cuando no hay claro

Definiciones y características

- **PCAP**: captura completa de paquetes. Característica: máximo detalle, pero pesada.
- **NetFlow/IPFIX**: metadatos de flujos (quién habló con quién, cuánto). Característica: liviano y escalable, sin contenido.
- **Beaconing**: comunicación periódica de un implante con su C2. Característica: intervalos regulares delatan el patrón.

- **Túnel DNS:** exfiltración disfrazada de consultas DNS. Característica: subdominios largos y muchas consultas TXT.
- **Zeek (antes Bro):** analizador de red que genera logs estructurados (conn, dns, http, ssl...). Característica: convierte PCAP en tablas analizables.
- **JA3/JA3S:** huellas del handshake TLS. Característica: identifican clientes/servidores incluso cifrados.
- **Reensamblado de flujo (Follow TCP Stream):** reconstruye la conversación de una sesión. Característica: revela credenciales y comandos en claro.

Herramientas y preparación

- **Captura:** `tcpdump`, `dumpcap`.
- **Análisis:** **Wireshark** y **tshark**, **Zeek**, **NetworkMiner** (extracción de archivos), **RITA** (detección de beaconing sobre logs de Zeek).
- **Muestras:** usa PCAPs propios o datasets públicos de práctica (por ejemplo, capturas de Malware-Traffic-Analysis con fines educativos). **Analiza malware solo en laboratorio aislado.**

Laboratorio guiado

Usa un PCAP propio o una muestra pública de entrenamiento.

1. Estadística rápida del PCAP con tshark:

```
bash tshark -r captura.pcap -q -z conv,tcp
```

2. Filtra tráfico HTTP y extrae hosts contactados:

```
bash tshark -r captura.pcap -Y "http.request" -T fields -e http.host -e http.request.uri
```

3. En Wireshark, usa *Follow* → *TCP Stream* sobre una sesión sospechosa para ver la conversación completa.
4. Extrae archivos transferidos: - Wireshark: **File** → **Export Objects** → **HTTP**. - NetworkMiner: carga el PCAP y revisa la pestaña *Files*.
5. Detecta túnel DNS buscando subdominios largos y muchas TXT:

```
bash tshark -r captura.pcap -Y "dns" -T fields -e dns.qry.name | sort | uniq -c | sort -rn | head
```

6. Procesa el PCAP con Zeek:

```
bash zeek -r captura.pcap cat conn.log | zeek-cut id.orig_h id.resp_h id.resp_p duration
```

7. Busca beaconing: analiza `conn.log` con RITA o calcula intervalos regulares hacia una misma IP externa.
8. Con TLS, revisa `ssl.log` y las huellas JA3 para identificar clientes anómalos.

Ejercicios

1. Filtra en Wireshark solo el tráfico de una IP y un puerto concretos.
2. Extrae un archivo transferido por HTTP de un PCAP.

3. Identifica un patrón de beaconing por su periodicidad.
4. Detecta un túnel DNS por el volumen y forma de las consultas.
5. Usa zeek-cut para listar las diez conversaciones más largas.
6. Explica qué puedes y qué no puedes ver en tráfico TLS.

Reto verificable

Dado un PCAP que contiene un canal C2 con beaconing y una exfiltración de datos, identifica la IP del C2, el intervalo de beaconing y qué se exfiltró.

Criterio de aceptación: reportas la IP/puerto del C2, el intervalo aproximado del beacon (con evidencia de la periodicidad), el método de exfiltración (DNS/HTTP) y, si es posible, el contenido o el tamaño de lo exfiltrado.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
No ves contenido, solo cifrado	Es TLS. Analiza metadatos (SNI, JA3, tamaños) en vez del claro.
Wireshark se cuelga con PCAP grande	Demasiado en memoria. Filtra con tshark o divide con <code>editcap</code> .
No detectas el beacon	Jitter aleatorio del malware. Analiza distribución de intervalos, no valores exactos.
Export Objects vacío	El archivo va fragmentado o cifrado. Prueba NetworkMiner o reensamblado manual.
Zeek no genera logs	Ruta o versión incorrecta. Verifica instalación y permisos de escritura.

Preguntas frecuentes

 **¿PCAP o NetFlow?** PCAP da detalle total pero no escala; NetFlow escala a toda la red pero sin contenido. En un caso serio usas ambos.

 **¿Puedo descifrar TLS?** Solo si tienes las claves o el `SSLKEYLOGFILE`. Sin ellas, trabajas con metadatos: SNI, certificados, JA3, tamaños y tiempos.

 **¿Cómo se ve un túnel DNS?** Muchas consultas a un mismo dominio con subdominios largos y aleatorios, a menudo tipo TXT o NULL.

 **¿Zeek reemplaza a Wireshark?** No: Zeek resume a escala; Wireshark inspecciona a fondo. Se complementan.

Referencias

- Wireshark: <https://www.wireshark.org/docs/>
- Zeek: <https://docs.zeek.org/>
- NetworkMiner: <https://www.netresec.com/?page=NetworkMiner>
- RITA (beaconing): <https://github.com/activecm/rita>

Siguiente clase

Clase 209 - Analisis de linea de tiempo (timeline)